

RESEARCH ARTICLE

Toward Secure and Transparent Global Authentication: A Blockchain-Based System Integrating Biometrics and Subscriber Identification Module

NAVID KHALILI¹, DIMITRIOS MAKRAKIS¹, YASER BASERI²,
AND ABDELHAKIM SENHAJI HAFID²

¹School of Electrical Engineering and Computer Science, University of Ottawa, Ottawa, ON K1N 6N5, Canada

²Department of Computer Science and Operations Research, University of Montreal, Montreal, QC H3T 1J4, Canada

Corresponding author: Navid Khalili (nkhal083@uottawa.ca)

This work was supported in part by the Natural Sciences and Engineering Research Council of Canada (NSERC) and Flex Group (<https://flexgroups.com>).

ABSTRACT The growing reliance on e-government services necessitates robust and secure user authentication. Existing solutions often suffer from limitations such as lack of transparency, compromise of user privacy, and reliance on a central server, thus introducing a single point of failure (SPOF). This paper proposes B²-GAS, a novel Biometric and Blockchain-based Global Authentication System, that addresses these shortcomings. B²-GAS leverages user biometrics on smartphones for strong identification and isolates sensitive cryptographic operations within a secure enclave on a SIM card. This approach safeguards user privacy and data security. By employing blockchain technology, B²-GAS eliminates SPOFs, ensures tamper-proof transaction storage, and guarantees transparency. Unlike existing protocols, which often rely on theoretical analysis, B²-GAS utilizes an emulated environment to assess its performance under realistic conditions. This allows for a more practical evaluation compared to purely theoretical approaches. B²-GAS exerts multiple factors during authentication including biometrics, a password, and a secret parameter to further enhance security. Rigorous security proofs demonstrate B²-GAS's resistance to user impersonation, offline password-guessing, replay attacks, and brute-force attempts. Evaluation using the emulated environment and blockchain simulations demonstrates B²-GAS security parameters, performance, and computational overheads. By combining biometrics, secure SIM enclaves, and blockchain, B²-GAS offers a unique and robust authentication solution for diverse e-government services in smart cities.

INDEX TERMS Authentication, smart card, biometrics, smart cities, blockchain, e-government.

I. INTRODUCTION

The rise of software applications in Smart Cities has revolutionized citizen interaction and automated municipal processes. This has led to increased government involvement in city management through Electronic Government (e-gov) initiatives [1]. E-gov facilitates the transition from traditional in-person services to convenient electronic services, delivered via the Internet. However, securing access to these Electronic Services (e-services) necessitates a robust and reliable Global Authentication System (GAS).

The associate editor coordinating the review of this manuscript and approving it for publication was Zijian Zhang¹.

Government e-services encompass a wide range, from issuing drivers' licenses and passports to verifying information for various administrative procedures [2]. Global Authentication Systems (GAS) face significant security challenges, particularly when handling sensitive citizen data stored within government institutions on central servers. These challenges include maintaining the confidentiality and integrity of user identities, which is paramount for ensuring user security and privacy [3]. In Addition, the authentication process requires transparency and an immutable record of activities for all parties involved, fostering accountability and trust. Moreover, GAS must efficiently handle potentially high volumes of authentication requests; thus, it must be

scalable so that it can meet the needs of modern e-government services [4]. This can be achieved by distributing the processing loads among various parties and minimizing the computational overhead.

Traditional authentication methods often require cumbersome user registrations across multiple platforms, potentially compromising user privacy by exposing users' personal data to third parties for verification [5]. Furthermore, scalable solutions capable of handling large transaction volumes per second are essential for effective service delivery in Smart Cities [6].

This study proposes a Biometric and Blockchain-based Global Authentication System (B²-GAS) to address these challenges. B²-GAS integrates biometric authentication, blockchain technology, and Subscriber Identification Module (SIM) technology. B²-GAS aims to enhance both the security and privacy of user authentication in e-gov services by eliminating a single point of failure (SPOF) and utilizing secure enclaves. This novel framework establishes a secure, privacy-preserving, and transparent authentication system tailored for e-government services.

A. CONTRIBUTIONS

This study introduces significant advancements in user authentication for e-government services through the following key contributions:

- **Secure and Privacy-Preserving Design:** B²-GAS integrates biometrics and SIM technology to ensure robust user authentication while preserving privacy through secure enclaves in the SIM card environment. This approach safeguards user credentials and sensitive data.
- **Elimination of a Single Point of Failure (SPOF):** By leveraging blockchain technology, B²-GAS eliminates the risk of a single point of failure, ensuring system resilience and reliability.
- **Scalable and Transparent System:** B²-GAS guarantees tamper-proof transaction storage and the scalability that blockchain offers. It also enables transparency across a distributed network, with efficient transaction processing.
- **Comprehensive Solution:** B²-GAS addresses the limitations of existing systems by integrating biometric authentication, SIM-based security, and blockchain technology. This combination offers a secure, transparent, and privacy-preserving global authentication solution.
- **Application in Smart Cities:** B²-GAS is tailored for smart city environments, facilitating secure and seamless interactions between citizens and government services, thereby enhancing the efficiency and user experience of e-government services.

B. ORGANIZATION

The remainder of this paper is organized as follows: Section II reviews the existing literature on blockchain-based authentication systems. Section III examines the foundational

technologies that underpin the proposed system. Section IV elaborates on the system architecture and security models of B²-GAS, detailing its components and operational framework. Section V outlines the design and construction of the proposed B²-GAS scheme. Section VI presents the security evaluation of B²-GAS. Section VII provides a comprehensive evaluation of the B²-GAS system, encompassing both theoretical analysis and empirical validation of its performance. Finally, Section VIII concludes the paper with a summary of the findings, discusses future research directions, and emphasizes the significance of B²-GAS in advancing secure and scalable authentication solutions for e-government services.

II. RELATED WORKS

User authentication has been a cornerstone of cybersecurity research with a focus on enhancing security, scalability, and privacy. However, existing solutions often struggle to achieve all the three simultaneously. This section analyzes related work on the integration of biometrics and blockchain technology for user authentication, highlighting their strengths and limitations compared to the proposed B²-GAS system.

Several recent studies explored the integration of biometrics and blockchain technology for user authentication. Yang et al. [7] highlighted the use of biometrics and blockchain to enhance system security. However, their work lacks a specific biometric implementation, and their use of the Ethereum blockchain could incur high costs for ethers. AlRousan et al. [8] proposed a two-factor authentication system that employed biometrics and One-Time Passwords. In this system, passwords are generated on mobile applications and user biometrics are sent over the Internet to governmental servers for verification. However, these mechanisms pose security risks, such as exposing biometric files during their transfer through the Internet and susceptibility to malware attacks, because the relevant software resides in a non-secure smartphone environment. Geteloma et al. [9] suggested a three-layer web-based application model with a Smart Card carrying cryptographic materials and user identities in the second layer. Although Smart Cards have been considered, the specifics of biometric matching and authentication remain unclear. Additionally, a centralized database that stores user data introduces tampering risk. Maazouz et al. [10] introduced a Mobile ID to replace the plastic ID cards. A Mobile ID carries an encrypted version of the user's biometrics in a SIM card that is transmitted to governmental kiosks via Near-Field Communication (NFC) for authentication on a remote server. However, sending biometrics over NFC is susceptible to various attacks, such as Eavesdropping, Man-in-the-Middle, and Replay attacks.

Xiang et al. [11] proposed an identity management and user authentication scheme specifically designed for e-health systems, incorporating the use of a Smart Card, three authentication factors, and a blockchain network for record management rather than an authentication process. However, Ahmed et al. [12] highlighted that Xiang et al.'s

TABLE 1. Comparison of existing authentication systems integrating biometrics and blockchain technology.

Reference	Smartphone compatible	Biometrics	Blockchain	Verification	Smart Card	Multi-factor	No SPOF
Yang et al. (2019) [7]	✓	N/A	✓	×	×	×	✓
Alrousan et al. (2020) [8]	×	✓	×	Remote	×	✓	×
Getelo et al. (2019) [9]	×	✓	×	N/A	✓	✓	×
Maazouz et al. (2014) [10]	×	✓	×	Remote	✓	✓	×
Xiang et al. (2020) [11]	×	✓	record-keeping	Local & Remote	✓	✓	×
Paez et al. (2020) [13]	×	✓	record-keeping	Local & Remote	✓	✓	×
Elisa et al. (2023) [14]	×	×	record-keeping	Remote	×	×	×
Elisa et al. (2023) [15]	×	×	✓	Remote	×	×	✓
Al-Ameri et al. (2020) [16]	✓	×	✓	Remote	×	×	✓
B²-GAS	✓	✓	✓	Local & Remote	✓	✓	✓

(✓): Supported, (×): Not supported, (N/A): Not Applicable.

scheme is susceptible to various attacks such as phishing and spoofing. Páez et al. [13] proposed an electronic identification (e-ID) architecture tailored to governmental offices, wherein a template is stored in a Smart Card. Despite the incorporation of blockchain technology for record-keeping purposes, reliance on central authority during the authentication process remains problematic. Furthermore, the architecture is not compatible with smartphone usage. Elisa et al. [14] proposed a blockchain-based framework for e-governments that relies heavily on the use of public and private keys stored in a digital wallet. However, the lack of multi-factor authentication in this system renders it vulnerable to identity theft and unauthorized access. Similarly, the framework proposed in [15] assumes that users keep their secret keys secure, although the possibility of identity theft remains. Al-Ameri et al. [16] proposed a mutual authentication system for e-services that incorporates two-factor authentication using a password and a private key. However, the authors did not provide specific information on the security of these factors on the user side. Additionally, the system assumes secure communication via the use of Virtual Private Networks (VPNs) that impact performance during periods of high demand.

In conclusion, existing blockchain-based authentication systems demonstrate diverse approaches yet frequently fall short in balancing robust security, scalability, and user privacy. While biometrics enhance security in some systems (e.g., [7], [8], [9], [10], [11]), they often suffer from insecure biometric storage or vulnerabilities during transmission. Additionally, many systems overrely on blockchain for record-keeping while maintaining centralized authentication, creating single points of failure (e.g., [11], [13]). The absence of multi-factor authentication in certain proposals (e.g., [14], [15], [16]) leaves users susceptible to identity theft. Furthermore, a notable oversight in several works (e.g., [9], [13]) is the lack of smartphone compatibility, which hinders user convenience.

The proposed B²-GAS system addresses these limitations by offering a comprehensive solution that integrates biometrics, secure enclaves within a SIM card environment, and blockchain technology. This innovative design ensures strong user authentication, isolates sensitive data, and eliminates SPOFs through distributed ledger technology

for e-government services in smart cities. As shown in the comparison table, B²-GAS surpasses the existing systems by simultaneously achieving security, scalability, privacy, and multi-factor authentication on a smartphone platform. Table 1 presents a comparative view of the existing systems and B²-GAS.

III. TECHNOLOGICAL FOUNDATIONS

Secure, efficient, and scalable systems rely on strong foundations for enabling technologies. This section explores the essential components underpinning our proposed solution: Smart Cards for secure computing environments, blockchain for tamper-proof data management, cryptography for data protection, biometrics for robust user authentication, and properties of lightweight authentication protocols designed for resource-constrained devices. These technologies collectively constitute the building blocks of the proposed system.

A. SMART CARDS

A Smart Card is a secure and isolated environment that has computing capabilities. A card is considered smart if it is uniquely identifiable, hard to tamper with, and supports cryptographic functionalities [17]. Examples include Magnetic Stripe Cards, Chip Cards, Microprocessor Chip Cards, Contactless Smart Cards, such as MIFARE, and Smart Tokens. Smart cards host operating systems (e.g., Java Card and MULTOS) to enhance security and support multi-application architecture [18], [19]. Java SIM, a specific Java Card, includes pre-installed applets and APIs for SIM modules. MULTOS supports a Modular Arithmetic API (MAA), which is convenient for advanced authentication protocols.

B. BLOCKCHAIN

Blockchain (BC) technology, originating in Bitcoin in 2008, has become a widely adopted Distributed Ledger Technology (DLT) rooted in the concept of timestamping for digital document authenticity [20]. Blockchain can be categorized into permissioned and permissionless types. Permissioned blockchains restrict participation to preauthorized nodes, which are suitable for controlled access scenarios [21]. This work employs Hyperledger Fabric, a prominent platform for permissioned blockchains that integrates a Membership

Service Provider (MSP) with a standalone Certificate Authority (CA) to manage user identities within the network [22].

Smart Contracts (SCs) are self-executing programs on blockchain nodes triggered by user transactions. They leverage blockchain attributes such as transparency, immutability, and security, forming the foundation for decentralized applications [23].

C. BIOMETRICS

Biometrics are categorized into two types: behavioral and physiological. The first category consists of human biological characteristics such as voice, signature, and keystroke, whereas the second category includes physical characteristics such as face, fingerprint, and iris [24]. Generally, biometrics offers enhanced security and convenience compared to traditional text-based passwords. The choice between physiological and behavioral biometrics for user authentication depends on the specifications of the operating scenario. While this study utilizes physiological biometrics supported by current smartphones, the designed technology remains adaptable to the potential use of behavioral biometrics with smartphones.

Biometric matching procedures on Smart Cards can be performed using either On-card or Off-card methods. In the On-card matching approach, a device with a biometric sensor, such as a smartphone, provides a real-time biometric template to a card. The matching process is executed within the card itself, where the registered template is stored. Conversely, in the Off-card scenario, the Smart Card supplies the registered template to a secondary device such as a smartphone. The reading of the real-time template and the matching process take place on the smartphone [25].

Modern Smartphones (SPs) are equipped with powerful hardware, including processors, memory, and sensors. A notable feature of SPs is the integration of biometric sensors, offering a fast, accurate, and convenient unlocking mechanism in contrast to traditional Personal Identification Numbers (PINs). Beyond unlocking, biometric sensors on SPs provide APIs for software applications to locally authenticate users based on their registered biometrics. This service ensures that no biometric characteristics are transmitted to third-party applications, and it does not grant access to registered biometrics. The entire authentication process takes place within an isolated environment in SPs, with only the authentication result sent to third-party applications in the form of a Boolean value (T: True, F: False) [26].

D. BIOMETRIC FUZZY EXTRACTORS (BFE)

Fuzzy extractors are based on extracting fuzzy values from dissimilar yet related inputs, thereby making them suitable for cryptographic operations. A biometric fuzzy extractor generates a random string k and helper τ from a biometric template for future use, as shown in Figure 1. This process typically involves two main functions [27]:

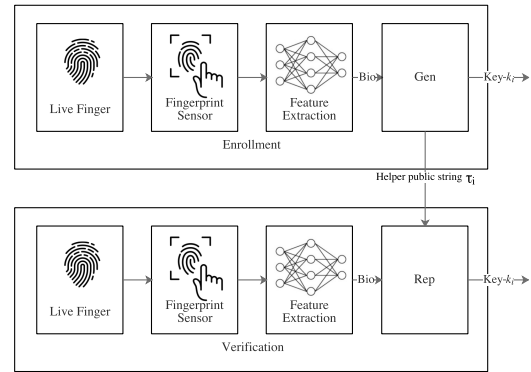


FIGURE 1. Biometric fuzzy extractor.

- **Probabilistic Generation (Gen):** This function extracts (k_i, τ_i) from a biometric template Bio_{U_i} .
- **Deterministic Reproduction (Rep):** The Rep function takes a helper τ_i and a new biometric template Bio_{U_i} as inputs to reproduce the same k_i .

In our proposed system, this mechanism is utilized to authenticate users by leveraging their pre-stored helper τ in the SIM card, which is established from the user's biometric template during the registration process.

E. ELLIPTIC CURVE CRYPTOGRAPHY

Elliptic Curve Cryptography (ECC) is a public key technique known for high security with smaller key sizes compared to RSA, leveraging the algebraic structure of elliptic curves over finite fields [28]. An elliptic curve E over a finite field $\mathbb{F}_p$ is defined as follows:

$$E : y^2 = x^3 + ax + b \mod p,$$

where $4a^3 + 27b^2 \neq 0$. The set of points that satisfy this equation, along with a point at infinity denoted by $\mathcal{O}$, forms an additive abelian group G . These points define the operational domain for ECC.

ECC operations include point addition and point doubling, which are fundamental for combining two points or doubling a point on a curve. These operations are defined based on a specific addition law for points on an elliptic curve, which differs from the usual addition of points in the coordinate plane. Point multiplication is a repeated point addition: for $k \in \mathbb{Z}^+$ and $P \in E(\mathbb{F}_p)$, $k \cdot P$ denotes the sum of k copies of P . These operations underpin the ECC-based cryptographic algorithms.

Key generation in ECC involves selecting a secret key SK and computing the corresponding public key $PK = SK \cdot P$, where P is the generator point on the curve. ECC supports the Elliptic Curve Digital Signature Algorithm (ECDSA) for digital signatures and Elliptic Curve Diffie-Hellman (ECDH) for secure key exchange.

ECC is essential in our approach for efficient security using smaller keys (e.g., a 256-bit ECC key matches a 3072-bit RSA key). Its faster computations and lower resource usage make

it ideal for smartphones and SIM cards, ensuring secure key generation, authentication, and session-key establishment.

F. LIGHTWEIGHT AUTHENTICATION PROTOCOL

In resource-constrained environments such as SIM cards, a lightweight authentication protocol plays a crucial role in enabling secure and efficient communication between two parties without the need for intermediaries. The essential attributes for a suitable protocol are as follows:

- **Security Properties:** An effective authentication protocol must be resilient to several attacks and satisfy specific properties, as outlined in [29]. Anonymity ensures the protection of users' real identities during message exchanges, whereas untraceability guarantees the confidentiality of users' behavior in these exchanges. Mutual Authentication establishes an agreement between two parties in the authentication process without involving an intermediary. The protocol should prevent Replay Attacks using timestamps and random numbers and thwart malicious parties from resending messages [30]. It should also defend against Insider Attacks by safeguarding identities and secrets during user registration and avoiding transmission over public channels. The use of nonce and arbitrary numbers enhances the prevention of insider data theft. Mitigating Man-in-the-middle (MITM) attacks, where a malicious entity interferes with communication by modifying and resending messages, is crucial through Mutual Authentication [31]. Finally, the protocol must address Stolen Smart Card/Device Attacks, which occur when the physical capture of the device leads to the extraction of valuable information such as credentials. Solutions involve randomization and the use of one-way hash functions [30], [31].
- **Intermediary device:** Given the resource limitations of IoT devices, protocols often utilize intermediary devices, such as gateways to aid authentication between restricted devices [32]. However, for resource-constrained devices such as SIM cards, a suitable lightweight protocol should facilitate direct communication between parties without intermediaries.
- **Cryptography schemes:** Elliptic Curve Cryptography (ECC) operations such as point addition, point multiplication, exclusive-or (XOR) operations, and one-way hash functions are particularly suitable for resource-constrained devices due to their efficiency and security properties [30].
- **Authentication factors:** Incorporating multiple authentication factors enhances security by diversifying the verification process [8]. A robust lightweight protocol should support the integration of various factors to strengthen the user authentication.
- **Communication and Computational overhead:** Efficiency is paramount in resource-constrained environments. Therefore, a lightweight authentication

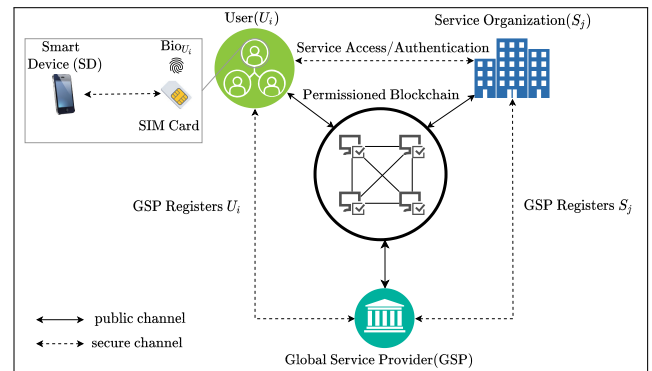


FIGURE 2. Architecture of B²-GAS.

protocol must minimize both the computation and communication overhead to operate effectively on devices with limited processing capabilities [29].

These properties are critical for designing lightweight authentication protocols that ensure secure communication and user privacy in resource-constrained environments.

IV. SYSTEM AND SECURITY MODELS

The proposed system requires the incorporation of three types of devices: SIM card, Smart Device (SD), and Biometric Recording and Storing Device (BRSD). The SIM card functions as a computational unit with secure information-processing capabilities within an isolated environment. The SD serves as a smart device that accommodates the SIM card and supplies essential functionalities, including power. BRSD refers to sensors and storage devices that capture and store users' biometrics throughout the lifecycle of the system. In our work, a smartphone is deemed a good choice for SD, as it hosts the SIM card and provides biometric sensors. The proposed system comprises three entities:

1. **Global Service Provider (GSP):** The GSP is a trusted party, typically the government responsible for the registration of entities in the network. It has the right and ability to authorize the inclusion of nodes in the blockchain network.
2. **User (U):** Users in our system are individuals who act as service consumers. A user possesses a Smart Device (SD) equipped with a SIM card and engages with the system for various functionalities.
3. **Service Organization (SO):** An SO is an entity that offers a service to a User (U) and requires user authentication before providing a service. Health Organizations are representative cases of such organizations; they authenticate patients (or Users) before providing services.

The architecture of our proposed system is illustrated in Figure 2. GSP is responsible for registering entities (User and SO) within the system. SO and User interact when User requests a service. Additionally, the blockchain network records all the transactions between these parties on its tamper-resistant ledger.

TABLE 2. B²-GAS notations.

Term	Description
GSP	Global Service Provider
SO	Service Organization
SK _{GSP}	Secret key of GSP
PK _{GSP}	Public key of GSP
S_j	j^{th} server of SO
SC	Smart Contract
α_{S_j}	Additional data for j^{th} server of SO
ID _{S_j}	Identity of j^{th} server of SO
PK _{S_j}	Public key of j^{th} server of SO
U_i	i^{th} user
ID _{U_i}	Identity of i^{th} user
PW _{U_i}	Password of i^{th} user
G	Elliptic curve group
P	Generator of G
SK _{i,j}	Session-key between U_i and S_j
Enroll _{BC} (.)	Enrollment function of blockchain CA
Enc _{PK} (.)	Encryption function with public key PK
$\dashrightarrow$	Secure channel
$\rightarrow$	Public channel
$\oplus$	XOR operation
$\parallel$	Concatenation
$H_i(\cdot)$	Hash function ($0 \leq i \leq 6$)
Bio _{U_i}	Biometrics data of i^{th} user
Gen(.)	Probabilistic generation function
Rep(.)	Deterministic reproduction function
k_i	Random string derived from biometrics
τ_i	Public reproduction parameter for biometrics
BID _{S_j}	Blockchain identity of S_j
Data _{U_i, S_j}	Registration data of U_i with S_j
$\mathbb{Z}_q^*$	Multiplicative group of integers modulo q
QST _{U_i}	Security questions for account recovery of U_i
ANS _{U_i}	Answers to security questions by U_i

V. CONSTRUCTION OF BIOMETRIC AND BLOCKCHAIN-BASED GLOBAL AUTHENTICATION SYSTEM (B²-GAS)

In this section, we outline the construction of the proposed B²-GAS, which consists of three phases: Setup Phase, Registration Phase, and Authentication Phase. The terminology used in these phases are summarized in Table 2.

A. SETUP PHASE

In this phase, the Global Service Provider (GSP) performs the following steps:

Step 1. Set Default Values and System Parameters: The GSP selects two large prime numbers p and q , and defines a non-singular elliptic curve $E : y^2 = x^3 + ax + b \pmod{p}$.

Step 2. Select Cryptographic Parameters: The GSP chooses a secret key $SK_{GSP} \in \mathbb{Z}_q^*$ and computes its corresponding public key $PK_{GSP} = SK_{GSP} \cdot P$, where P is a generator of elliptic curve group G .

Step 3. Obtain Blockchain Identity: The GSP acquires its blockchain identity from Hyperledger Fabric's certificate authority, thereby enabling it to register with other entities within the network.

Step 4. Define Hash Functions Used in the System: Finally, the GSP specifies the hash functions employed in the system:

$$\begin{aligned}
 H_0 &: \{0, 1\}^* \rightarrow \mathbb{Z}_q^*, \\
 H_1 &: \{0, 1\}^* \times G \rightarrow \mathbb{Z}_q^*, \\
 H_2 &: G \times \mathbb{Z}_q^* \rightarrow \mathbb{Z}_q^*, \\
 H_3 &: G \rightarrow \{0, 1\}^*, \\
 H_4 &: \{0, 1\}^* \times G \times G \rightarrow \{0, 1\}^*, \\
 H_5 &: \{0, 1\}^* \times G \times G \times \{0, 1\}^* \rightarrow \mathbb{Z}_q^*, \\
 H_6 &: \{0, 1\}^* \rightarrow \{0, 1\}^*
 \end{aligned}$$

These hash functions are crucial for various cryptographic operations within B²-GAS.

B. REGISTRATION PHASE

User registration occurs in secured governmental locations known as Global Service Provider's Locations (GSPL), where a user and GSP representative are present. The user's smartphone is equipped with a SIM card hosting a trusted application.

Step 1. User Provides Identity and Credentials: The user provides their identity ID _{U_i} , password PW _{U_i} , biometric information Bio _{U_i} , and a nonce n_0 .

Step 2. Biometric Data Processing: Using the biometric fuzzy extractor function Gen, the user computes a random string k_i and helper value τ_i from Bio _{U_i} .

Step 3. Hash Calculation and Transmission: The user calculates $RPW_{U_i} = H_0(PW_{U_i} || n_0 || k_i)$. These, along with τ_i , are securely sent to the GSP.

Step 4. GSP Processes User Data: Upon receiving the user's data, GSP performs cryptographic operations:

- Selects m_{U_i} and computes $\Psi_{U_i} = m_{U_i} \cdot P$.
- Calculates $\varphi_{U_i} = [H_1(ID_{U_i} || \Psi_{U_i}) \cdot SK_{GSP} + m_{U_i}] \pmod{q}$.
- Forms $\beta_{U_i} = (\Psi_{U_i} || \varphi_{U_i}) \oplus H_6(ID_{U_i} || RPW_{U_i})$.
- Generates authentication token $Auth_{U_i} = H_2(\Psi_{U_i} || \varphi_{U_i})$.
- Prepares account recovery questions QST _{U_i} .

The GSP securely sends $(\beta_{U_i}, Auth_{U_i}, QST_{U_i})$ to the user.

Step 5. User Completes Registration: The user stores β_{U_i} , $Auth_{U_i}$, n_0 , and τ_i for future use, provides answers ANS _{U_i} to security questions, and sends them securely to the GSP.

Step 6. Final Transaction and Storage: GSP encrypts the questions and answers using its public key PK_{GSP} to form the registration transaction $Data_{U_i} = (ID_{U_i}, \Psi_{U_i}, Enc_{PK_{GSP}}(QST_{U_i}), Enc_{PK_{GSP}}(ANS_{U_i}), \tau_i)$. The transaction is then stored in the blockchain network.

The complete message communication structure is summarized in Table 3, which integrates the biometric fuzzy extractor functionality and ensures secure data transmission between the user and GSP.

The SO's registration follows a similar secure process with GSP, ensuring the integrity and confidentiality of identity and registration data, as detailed in Table 4.

TABLE 3. User registration.

User U_i	Global Service Provider GSP
Selects ID_{U_i}, PW_{U_i}, n_0 Provides Bio_{U_i} Computes $(k_i, \tau_i) = \text{Gen}(Bio_{U_i})$ Computes $RPW_{U_i} = H_0(PW_{U_i} n_0 k_i)$	Selects $m_{U_i} \in \mathbb{Z}_q^*$ Computes $\Psi_{U_i} = m_{U_i} \cdot P$ Computes $\varphi_{U_i} = [H_1(ID_{U_i} \Psi_{U_i}) \cdot SK_{GSP} + m_{U_i}] \bmod q$ Computes $\beta_{U_i} = (\Psi_{U_i} \varphi_{U_i}) \oplus H_0(ID_{U_i} RPW_{U_i})$ Computes $Auth_{U_i} = H_2(\Psi_{U_i} \varphi_{U_i})$ Generates QST_{U_i}
Stores $\beta_{U_i}, Auth_{U_i}, n_0, \tau_i$ Loads $\text{Gen}(\cdot), \text{Rep}(\cdot)$ into SIM card Provides ANS_{U_i}	Stores $\{ID_{U_i}, RPW_{U_i}, \tau_i\}$ Stores $\{\beta_{U_i}, Auth_{U_i}, QST_{U_i}\}$ Stores $\{ANS_{U_i}\}$ Data $_{U_i} = (ID_{U_i}, \Psi_{U_i}, \text{Enc}_{PK_{GSP}}(QST_{U_i}), \text{Enc}_{PK_{GSP}}(ANS_{U_i}), \tau_i)$ Stores Data $_{U_i}$ on blockchain

TABLE 4. Service organization (SO) registration.

Service Organization S_j	Global Service Provider GSP
Selects ID_{S_j} Provides optional additional data α_{S_j}	Selects $m_{S_j} \in \mathbb{Z}_q^*$ Computes $PK_{S_j} = m_{S_j} \cdot P$ Computes $\sigma_{S_j} = SK_{GSP} \cdot m_{S_j}^{-1} - H_0(ID_{S_j}) \bmod q$ Computes $BID_{S_j} = \text{Enroll}_{BC}(ID_{S_j})$
Stores σ_{S_j}, BID_{S_j} Publishes ID_{S_j}, PK_{S_j} publicly	Stores $\{ID_{S_j}, \alpha_{S_j}\}$ Stores $\{PK_{S_j}, \sigma_{S_j}, BID_{S_j}\}$ Stores Data $_{S_j} = (ID_{S_j}, PK_{S_j}, \alpha_{S_j})$ on blockchain

C. AUTHENTICATION PHASE

This phase involves the User and the Service Organization negotiating a Session-key ($SK_{i,j}$) for future message exchanges. Due to the resource-constrained nature of SIM cards, a lightweight mutual authentication protocol is employed. This protocol is used when a user requests a service from Service Organizations (SOs). More details are provided in Table 5. The User obtains the SO's identity ID_{S_j} and public key PK_{S_j} from the SO since they are publicly available. First, the User must verify their identity locally on the smartphone by providing three authentication factors: Biometrics $Bio_{U_i}^*$, Password $PW_{U_i}^*$, and a previously stored value in SIM card β_{U_i} during user registration.

Step 1. User Obtains SO's Identity and Public Key: The User obtains the identity of the j^{th} server of the Service Organization (i.e., ID_{S_j}) and its public key PK_{S_j} .

Step 2. User Identity Verification on Smartphone: The User verifies their identity on the smartphone using a Fuzzy Extractor to reproduce a random string k_i^* via its Rep function, utilizing the newly provided user biometrics $Bio_{U_i}^*$ and the previously stored helper data τ_i in the SIM card. In this approach, the user U_i :

- Provides biometrics $Bio_{U_i}^*$, password $PW_{U_i}^*$, and SIM-stored β_{U_i} .
- Computes $k_i^* = \text{Rep}(Bio_{U_i}^*, \tau_i)$.
- Calculates $\Psi_{U_i} || \varphi_{U_i}$ by XORing $H_6(ID_{U_i}^* || H_0(PW_{U_i}^* || n_0 || k_i^*))$ with β_{U_i} .
- Computes the authentication string $Auth_{U_i}^* = H_2(\Psi_{U_i} || \varphi_{U_i})$ by applying hash function H_2 on the calculated value $\Psi_{U_i} || \varphi_{U_i}$.

- Verifies the equality of the newly generated authentication string $Auth_{U_i}^*$ with the previously stored value $Auth_{U_i}$ in the SIM card. If $Auth_{U_i}^*$ and $Auth_{U_i}$ do not match (due to a mismatch between the newly derived random string k_i^* from the provided biometrics $Bio_{U_i}^*$ or the newly entered user password $PW_{U_i}^*$ and those used during registration) authentication fails and the process ends; otherwise, it continues.

Step 3. Session-Key Establishment: In the context of secure communication, establishing a shared secret key between the two parties is essential. This key, known as a session-key ($SK_{i,j}$), safeguards the confidentiality and integrity of the data exchanged during a session. To establish a secure session-key between user (U_i) and service provider (S_j) over an insecure public channel, this process utilizes public key cryptography and message authentication codes (MAC) to achieve both secure key exchange and mutual authentication between user and service organization. In this process:

- U_i selects nonces $n_1, n_2 \in \mathbb{Z}_q^*$, calculates:

$$\begin{aligned}
 K &= n_1 \cdot [PK_{GSP} - H_0(ID_{S_j}) \cdot PK_{S_j}], \\
 M_{i,j} &= n_1 \cdot PK_{S_j}, \\
 EK_i &= n_2 \cdot P, \\
 \sigma_{U_i} &= \varphi_{U_i} + n_2 \bmod q, \\
 E_{U_i} &= H_3(K) \oplus (ID_{U_i} || \Psi_{U_i}),
 \end{aligned}$$

and sends $\{M_{i,j}, EK_i, E_{U_i}, \sigma_{U_i}\}$ to S_j over a public channel.

- S_j computes $K^* = \sigma_{S_j} \cdot M_{i,j}$, extracts ID_{U_i}, Ψ_{U_i} by computing $H_3(K^*) \oplus E_{U_i}$, which yields $(ID_{U_i} || \Psi_{U_i})$. Subsequently, S_j sends a verification request $\{PK_{S_j}, \Psi_{U_i}, EK_i, \sigma_{U_i}\}$ to the smart contract (SC).
- Upon receiving the request, the SC retrieves ID_{U_i} and ID_{S_j} from the blockchain, and verifies the legitimacy of the user through $\sigma_{U_i} \cdot P \stackrel{?}{=} H_1(ID_{U_i} || \Psi_{U_i}) \cdot PK_{GSP} + EK_i + \Psi_{U_i}$. SC audits the result of the verification on the blockchain and emits an event to S_j to query the network.
- If the verification is successful, S_j establishes the session-key $SK_{i,j}$ for U_i by selecting random m_{S_j} , computing $EK_j = m_{S_j} \cdot P$, and calculating:

$$\begin{aligned}
 EK_{i,j} &= m_{S_j} \cdot EK_j, \\
 SK_{i,j} &= H_4(ID_{U_i} || ID_{S_j} || EK_{i,j} || K^*), \\
 MAC &= H_5(ID_{U_i} || EK_j || K^* || SK_{i,j}),
 \end{aligned}$$

Ultimately, S_j sends $\{EK_j, MAC\}$ to U_i .

- U_i validates and confirms the message upon receiving it by calculating:

$$\begin{aligned}
 EK_{i,j} &= n_2 \cdot EK_j, \\
 SK_{i,j} &= H_4(ID_{U_i} || ID_{S_j} || EK_{i,j} || K), \\
 MAC^* &= H_5(ID_{U_i} || EK_j || K || SK_{i,j}),
 \end{aligned}$$

If MAC^* is equal to the received MAC (i.e., $MAC^* \stackrel{?}{=} MAC$), U_i authenticates the message, and the session-key $SK_{i,j}$ is established with S_j .

TABLE 5. Authentication and session-key establishment.

User U_i	Service Organization S_j	Smart Contract SC
Obtains ID_{S_j}, PK_{S_j} from SO		
Inputs $ID_{U_i}^*, PW_{U_i}^*$, Imprint Bio_{U_i}		
SIM card computes: $k_i^* = \text{Rep}(Bio_{U_i}^*, \tau_i)$		
$(\Psi_{U_i} \varphi_{U_i}) = H_0(ID_{U_i} H_0(PW_{U_i} n_0 k_i^*)) \oplus \beta_{U_i}$		
$Auth_{U_i} = H_2(\Psi_{U_i} \varphi_{U_i})$		
$Auth_{U_i}^? = Auth_{U_i}$, if not equal, rejects		
SIM card selects $n_1, n_2 \in \mathbb{Z}_q^*$		
$K = n_1 \cdot [PK_{GSP} - H_0(ID_{S_j}) \cdot PK_{S_j}]$		
$M_{i,j} = n_1 \cdot PK_{S_j}$		
$EK_j = n_2 \cdot P$		
$\sigma_{U_i} = \varphi_{U_i} + n_2 \mod q$		
$E_{U_i} = H_3(K) \oplus (ID_{U_i} \Psi_{U_i})$		
$\{M_{i,j}, EK_j, E_{U_i}, \sigma_{U_i}\}$		
Computes $K^* = \sigma_{S_j} \cdot M_{i,j}$		
Computes $H_3(K^*) \oplus E_{U_i} = (ID_{U_i} \Psi_{U_i})$		
$\{PK_{S_j}, \Psi_{U_i}, EK_j, \sigma_{U_i}\}$		
Selects ID_{U_i} from blockchain using Ψ_{U_i}		
Selects ID_{S_j} from blockchain using PK_{S_j}		
Computes $\sigma_{U_i} \cdot P \stackrel{?}{=} H_1(ID_{U_i} \Psi_{U_i}) \cdot PK_{GSP} + EK_j + \Psi_{U_i}$		
Audits the result on blockchain and logs the event with ID_{S_j}, Ψ_{U_i} , result, timestamp		
Emits an event to S_j		
← Queries blockchain →		
Evaluates the query, establishes session-key $SK_{i,j}$ for U_i		
Selects random m_{S_j}		
Computes $EK_j = m_{S_j} \cdot P$		
Computes $EK_{i,j} = m_{S_j} \cdot EK_j$		
Computes $SK_{i,j} =$		
$H_4(ID_{U_i} ID_{S_j} EK_{i,j} K^*)$		
Computes MAC		
$H_5(ID_{U_i} EK_j K^* SK_{i,j})$		
← $\{EK_j, MAC\}$ →		
Computes $EK_{i,j} = n_2 \cdot EK_j$		
Computes $SK_{i,j} =$		
$H_4(ID_{U_i} ID_{S_j} EK_{i,j} K)$		
Computes $MAC^* =$		
$H_5(ID_{U_i} EK_j K SK_{i,j})$		
Compares $MAC^* \stackrel{?}{=} MAC$, if equal, authenticates S_j message, establishes session-key; else, abort		

The mutually agreed session-key $SK_{i,j}$ encrypts all future communications between the User and the SO. Table 5 provides details of session-key agreement.

VI. SECURITY ANALYSIS

In this section, we provide formal security proofs for the B²-GAS protocol. We consider four main security properties: resistance to user impersonation, offline password-guessing, replay attacks, and brute-force attacks. We model these properties using standard game-based definitions and show that any Probabilistic Polynomial Time (PPT) adversary $\mathcal{A}$ breaking these properties with non-negligible probability would imply a PPT algorithm solving a known hard problem (e.g., the Discrete Logarithm Problem) or breaking a cryptographic primitive (e.g., a random oracle or fuzzy extractor security), which is assumed infeasible.

A. SECURITY ASSUMPTIONS

The security of the proposed B²-GAS protocol is based on the following cryptographic assumptions:

Assumption 1 (Discrete Logarithm Assumption (DLA)):

In an elliptic curve group G of prime order q with generator

P , given $A = aP$ for a randomly chosen $a \in \mathbb{Z}_q^*$, no PPT adversary can recover a except with negligible probability.

Assumption 2 (Random Oracle Model (ROM)): All hash functions $H_i(\cdot)$ are modeled as random oracles. Inverting or finding collisions in these random oracles occurs only with negligible probability.

Assumption 3 (Fuzzy Extractor Security): Given the helper data τ_i derived from a biometric Bio_{U_i} , no PPT adversary can recover the extracted random string k_i without a sufficiently close biometric input, except with negligible probability.

B. SECURITY DEFINITIONS AND PROOFS

Let λ denote the security parameter. A function $\mu(\lambda)$ is considered *negligible* if for every polynomial $p(\cdot)$, there exists a λ_0 such that for all $\lambda > \lambda_0$, $\mu(\lambda) < 1/p(\lambda)$. We assume that the runtime of all algorithms, including those of the adversary, is polynomial in λ . Security is defined using game-based models. For each security property, a challenger $\mathcal{C}$ interacts with an adversary $\mathcal{A}$, and the adversary's advantage in breaking the property is measured. We aim to show that this advantage is negligible.

Game 1 (Security Against User Impersonation Attack):

To prove the security of B²-GAS against user impersonation attacks, we define a security game $\mathcal{G}_{UIA}$ between $\mathcal{C}$ and $\mathcal{A}$:

- Setup:** $\mathcal{C}$ initializes the system by selecting elliptic curve parameters (G, q, P) , choosing a secret key $SK_{GSP} \in \mathbb{Z}_q^*$, and setting $PK_{GSP} = SK_{GSP} \cdot P$. It registers a user U_i with identity ID_{U_i} , password PW_{U_i} , biometric Bio_{U_i} , and a nonce n_0 . Using the fuzzy extractor, $(k_i, \tau_i) \leftarrow \text{Gen}(Bio_{U_i})$. The values $RPW_{U_i} = H_0(PW_{U_i} || n_0 || k_i)$, β_{U_i} , and $Auth_{U_i}$ are computed according to the protocol and stored. Relevant data is placed on the blockchain.
- Adversary's View:** $\mathcal{A}$ sees all public parameters, including PK_{GSP} , any public keys PK_{S_j} , and blockchain-stored data. $\mathcal{A}$ may query the random oracles at will.
- Winning Condition:** $\mathcal{A}$ wins if it produces a valid authentication transcript $(M_{i,j}, EK_i, E_{U_i}, \sigma_{U_i})$ that the service organization S_j and the smart contract SC accept as legitimate without $\mathcal{A}$ having knowledge of PW_{U_i} or Bio_{U_i} .

Advantage: The advantage of the adversary is defined as $\text{Adv}_{\mathcal{A}, \mathcal{G}_{UIA}}(\lambda) = \Pr[\mathcal{A} \text{ wins in } \mathcal{G}_{UIA}]$.

Theorem 1 (Security Against User Impersonation Attack): If the DLA holds, the fuzzy extractor is secure, and all H_i are random oracles, then for any PPT adversary $\mathcal{A}$, $\text{Adv}_{\mathcal{A}, \mathcal{G}_{UIA}}(\lambda)$ is negligible.

Assume for contradiction that there exists a probabilistic polynomial-time (PPT) adversary $\mathcal{A}$ that wins the user impersonation game $\mathcal{G}_{UIA}$ with non-negligible advantage $\varepsilon(\lambda)$, where λ is the security parameter.

Setup: The challenger $\mathcal{C}$ generates the system parameters, including an elliptic curve group G of order $q \approx 2^\lambda$ with generator P , the GSP key pair $(SK_{GSP}, PK_{GSP} = SK_{GSP} \cdot P)$, hash functions H_i modeled as random oracles, and fuzzy

extractor parameters for extracting k_i from user biometrics Bio_{U_i} . The user U_i registers with identity ID_{U_i} , password PW_{U_i} , and biometrics Bio_{U_i} . During registration, the fuzzy extractor outputs (k_i, τ_i) , where k_i is a random string and τ_i is helper data. The password-related hash $\text{RPW}_{U_i} = H_0(\text{PW}_{U_i} \| n_0 \| k_i)$ is computed, where n_0 is a random nonce. Additionally, the values $\Psi_{U_i} = m_{U_i} \cdot P$ and φ_{U_i} are generated using elliptic curve operations.

Adversary's Goal: To impersonate U_i , $\mathcal{A}$ must produce a valid authentication tuple $(M_{i,j}, \text{EK}_i, E_{U_i}, \sigma_{U_i})$ that passes verification. In particular, σ_{U_i} must satisfy $\sigma_{U_i} \cdot P \stackrel{?}{=} H_1(\text{ID}_{U_i} \| \Psi_{U_i}) \cdot \text{PK}_{\text{GSP}} + \text{EK}_i + \Psi_{U_i}$. Moreover, $\mathcal{A}$ must create values consistent with k_i and PW_{U_i} , since $\text{RPW}_{U_i} = H_0(\text{PW}_{U_i} \| n_0 \| k_i)$ and $\beta_{U_i}, \varphi_{U_i}, \Psi_{U_i}$ indirectly depend on these secret values.

Adversary's Strategy and Reductions: We consider three possible ways for $\mathcal{A}$ to win the game and reduce each to breaking an underlying cryptographic assumption.

- 1) *Breaking the Fuzzy Extractor:* If $\mathcal{A}$ succeeds without knowing k_i , it must derive k_i from the public helper value τ_i . The security of the fuzzy extractor ensures that for any PPT adversary $\mathcal{A}$, the probability of deriving k_i without access to the correct biometrics Bio_{U_i} is negligible:

$$\Pr[\mathcal{A} \text{ derives } k_i \mid \tau_i] \leq \epsilon_{\text{fuzzy}}(\lambda),$$

where $\epsilon_{\text{fuzzy}}(\lambda)$ is the fuzzy extractor's security advantage.

- 2) *Breaking the Hash Function H_0 :* If $\mathcal{A}$ cannot break the fuzzy extractor, it must still guess PW_{U_i} and k_i to compute $\text{RPW}_{U_i} = H_0(\text{PW}_{U_i} \| n_0 \| k_i)$. Since H_0 is modeled as a random oracle, the probability of finding a pre-image is bounded by:

$$\Pr[\mathcal{A} \text{ finds pre-image of } \text{RPW}_{U_i}] \leq \epsilon_{\text{hash-inversion}}(\lambda) = \frac{q_H}{2^n},$$

where q_H is the number of hash queries made by $\mathcal{A}$ and n is the output length of H_0 (e.g., $n = 256$).

- 3) *Breaking the DLA:* If $\mathcal{A}$ cannot break the fuzzy extractor or H_0 , it must forge valid elliptic curve values $\Psi_{U_i}, \varphi_{U_i}$, and σ_{U_i} consistent with PK_{GSP} . This task reduces to solving the Discrete Logarithm Problem (DLA). The probability of solving the DLA is negligible:

$$\Pr[\mathcal{A} \text{ solves DLA}] \leq \epsilon_{\text{DLA}}(\lambda),$$

where $\epsilon_{\text{DLA}}(\lambda)$ is the advantage of solving the DLA in G .

Combining the Probabilities: By the union bound, the adversary's overall success probability is bounded as:

$$\begin{aligned} \text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{UIA}}}(\lambda) &= \Pr[\mathcal{A} \text{ wins } \mathcal{G}_{\text{UIA}}] \\ &\leq \epsilon_{\text{fuzzy}}(\lambda) + \epsilon_{\text{hash-inversion}}(\lambda) + \epsilon_{\text{DLA}}(\lambda). \end{aligned}$$

Substituting the values:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{UIA}}} \leq \epsilon_{\text{fuzzy}}(\lambda) + \frac{q_H}{2^n} + \epsilon_{\text{DLA}}(\lambda).$$

Since each term on the right-hand side is negligible by the respective assumptions, the overall advantage of $\mathcal{A}$ is negligible. This contradicts the assumption that $\mathcal{A}$ has non-negligible advantage. Therefore, the B²-GAS protocol is secure against user impersonation attacks under the stated assumptions. $\square$

Game 2 (Security Against Offline Password Guessing Attack): We define a security game $\mathcal{G}_{\text{OPGA}}$ between $\mathcal{A}$ and $\mathcal{C}$ to demonstrate the protocol's resistance to offline password-guessing attacks.

- 1) **Setup:** Same as $\mathcal{G}_{\text{UIA}}$.
- 2) **Adversary's Goal:** $\mathcal{A}$ obtains RPW_{U_i}, τ_i , and tries to guess PW_{U_i} offline.
- 3) **Winning Condition:** $\mathcal{A}$ wins if it finds PW_{U_i} (and effectively k_i) allowing it to authenticate without further online queries.

Advantage: The advantage of the adversary in the above game is defined as $\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{OPGA}}}(\lambda) = \Pr[\mathcal{A} \text{ wins in } \mathcal{G}_{\text{OPGA}}]$.

Theorem 2 (Security Against Offline Password-Guessing Attack): Under the DLA, fuzzy extractor security, and the Random ROM for hash functions, for any PPT adversary $\mathcal{A}$, the advantage $\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{OPGA}}}(\lambda)$ is negligible.

We analyze the security of the protocol against offline password-guessing attacks using the security game $\mathcal{G}_{\text{OPGA}}$. Assume for contradiction that there exists a PPT adversary $\mathcal{A}$ with non-negligible advantage $\epsilon(\lambda)$ in winning $\mathcal{G}_{\text{OPGA}}$.

Setup: The challenger $\mathcal{C}$ initializes the system parameters as follows: it generates an elliptic curve group G of prime order $q \approx 2^\lambda$ with a generator P , and the GSP's key pair consisting of a secret key SK_{GSP} and a public key $\text{PK}_{\text{GSP}} = \text{SK}_{\text{GSP}} \cdot P$. Hash functions $H_0, H_1, \dots$ are modeled as random oracles. The challenger also sets up the fuzzy extractor with parameters for the biometrics Bio_{U_i} , such that $(k_i, \tau_i) \leftarrow \text{Gen}(\text{Bio}_{U_i})$, where k_i is a derived random string and τ_i is the helper value. The user U_i registers with the system by providing a password PW_{U_i} , which is chosen from a space of entropy H_{pw} , and biometrics Bio_{U_i} , which are used to generate k_i , along with a nonce n_0 to ensure session uniqueness. The password-related hash is computed as $\text{RPW}_{U_i} = H_0(\text{PW}_{U_i} \| n_0 \| k_i)$.

Adversary's Goal: The adversary $\mathcal{A}$ participates in $\mathcal{G}_{\text{OPGA}}$ and attempts to guess the password PW_{U_i} and the biometric-derived k_i offline. To succeed, $\mathcal{A}$ must produce a tuple $(\text{PW}_{U_i}^*, k_i^*)$ that satisfies: $\text{RPW}_{U_i}^* = H_0(\text{PW}_{U_i}^* \| n_0 \| k_i^*)$, where $\text{RPW}_{U_i}^*$ matches the original RPW_{U_i} .

Adversary's Strategy and Reductions: We identify three possible adversarial strategies and provide a reduction for each:

- 1) *Breaking the Fuzzy Extractor:* The fuzzy extractor outputs a random string k_i and helper value τ_i :

$$(k_i, \tau_i) \leftarrow \text{Gen}(\text{Bio}_{U_i}).$$

The helper value τ_i is public, but the fuzzy extractor guarantees that no adversary can derive k_i without the

exact biometric input Bio_{U_i} . Specifically:

$$\Pr[\mathcal{A} \text{ derives } k_i \mid \tau_i] \leq \epsilon_{\text{fuzzy}}(\lambda),$$

where $\epsilon_{\text{fuzzy}}(\lambda)$ is negligible.

Any adversary that succeeds in deriving k_i without Bio_{U_i} violates the fuzzy extractor's security.

- 2) **Breaking the Hash Function H_0 :** If the adversary cannot break the fuzzy extractor, it must still guess both PW_{U_i} and k_i to satisfy:

$$\text{RPW}_{U_i} = H_0(\text{PW}_{U_i} \parallel n_0 \parallel k_i).$$

Since H_0 is modeled as a random oracle, the probability of finding a valid pre-image for RPW_{U_i} without querying the oracle on the correct tuple $(\text{PW}_{U_i}, n_0, k_i)$ is negligible. Specifically:

$$\Pr[\mathcal{A} \text{ finds pre-image}] \leq \epsilon_{\text{hash-inversion}}(\lambda) = \frac{q_H}{2^n},$$

where q_H is the number of hash queries, and n is the output size of H_0 (e.g., $n = 256$).

- 3) **Brute-Force Guessing:** If the adversary attempts to guess the password PW_{U_i} and pair it with a guessed k_i , the probability of success is limited by the entropy of both:

$$P_{\text{guess}} = 2^{-H_{\text{pw}}} \cdot 2^{-H_k},$$

where H_{pw} is the entropy of the password space (e.g., 64 bits), and H_k is the entropy of the biometric-derived k_i (e.g., 40 bits). Even with multiple attempts, the combined probability remains negligible.

Combining the Probabilities: Using the union bound, the adversary's overall success probability is:

$$\begin{aligned} \text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{OPGA}}}(\lambda) &= \Pr[\mathcal{A} \text{ wins } \mathcal{G}_{\text{OPGA}}] \\ &\leq \epsilon_{\text{fuzzy}}(\lambda) + \epsilon_{\text{hash-inversion}}(\lambda) + P_{\text{guess}}. \end{aligned}$$

Substituting the bounds:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{OPGA}}}(\lambda) \leq \epsilon_{\text{fuzzy}}(\lambda) + \frac{q_H}{2^n} + 2^{-H_{\text{pw}}} \cdot 2^{-H_k}.$$

Since the adversary's advantage is negligible, the protocol is secure against offline password-guessing attacks under the stated assumptions. $\square$

Game 3 (Security Against Replay Attacks): We define a security game $\mathcal{G}_{\text{RA}}$ between an adversary $\mathcal{A}$ and a challenger $\mathcal{C}$ to demonstrate the resistance of the protocol to replay attacks.

- 1) **Setup:** Same as $\mathcal{G}_{\text{UIA}}$.
- 2) **Adversary's Goal:** The adversary $\mathcal{A}$ intercepts a valid authentication message $\{M_{i,j}, \text{EK}_i, E_{U_i}, \sigma_{U_i}\}$ and attempts to replay it later to impersonate a legitimate user U_i .
- 3) **Winning Condition:** $\mathcal{A}$ wins if it can produce a replayed message that is accepted by the blockchain-based verification as a fresh, valid authentication without modification.

Advantage: The adversary's advantage is defined as:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{RA}}}(\lambda) = \Pr[\mathcal{A} \text{ wins in } \mathcal{G}_{\text{RA}}].$$

Theorem 3 (Security Against Replay Attacks): Under the Discrete Logarithm Assumption (DLA) and the Random Oracle Model (ROM), for any PPT adversary $\mathcal{A}$, $\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{RA}}}(\lambda)$ is negligible.

Assume for contradiction that there exists a PPT adversary $\mathcal{A}$ that wins $\mathcal{G}_{\text{RA}}$ with non-negligible advantage $\epsilon(\lambda)$.

Setup: The challenger $\mathcal{C}$ generates the system parameters, including an elliptic curve group G of order q , a generator P , the GSP key pair $(\text{SK}_{\text{GSP}}, \text{PK}_{\text{GSP}} = \text{SK}_{\text{GSP}} \cdot P)$, and hash functions $H_0, H_1, \dots$ modeled as random oracles. The random oracle model ensures that $\mathcal{A}$ cannot predict or manipulate hash outputs without querying the oracle. Nonces n_1, n_2 are randomly chosen for each session, and all authentication attempts are logged on a blockchain, ensuring immutability and auditability.

Adversary's Goal: The adversary $\mathcal{A}$ participates in $\mathcal{G}_{\text{RA}}$ and attempts to impersonate a user U_i by replaying a previously intercepted authentication message:

$$\{M_{i,j}, \text{EK}_i, E_{U_i}, \sigma_{U_i}\}.$$

Adversary's Strategy: To win, $\mathcal{A}$ must produce a message that passes the blockchain-based verification:

$$\sigma_{U_i} \cdot P \stackrel{?}{=} H_1(\text{ID}_{U_i} \parallel \Psi_{U_i}) \cdot \text{PK}_{\text{GSP}} + \text{EK}_i + \Psi_{U_i}.$$

We identify two possible strategies for $\mathcal{A}$ and provide a reduction for each.

- 1) **Reusing the same intercepted message:** This strategy involves using the original nonces n_1, n_2 from the intercepted authentication attempt. All authentication attempts (including the nonces) are immutably logged on the blockchain. If $\mathcal{A}$ tries to replay the exact same message, the smart contract checks the blockchain for nonce freshness. Since these nonces have already been used, the replay fails verification. Thus:

$$P_{\text{reuse}} = \Pr[\mathcal{A} \text{ succeeds by replaying old nonces}] = 0.$$

- 2) **Forging fresh nonces and associated values:** To bypass nonce freshness checks, $\mathcal{A}$ must generate valid fresh nonces n_1^*, n_2^* and construct corresponding $\Psi_{U_i}^*, \text{EK}_i^*$, and $\sigma_{U_i}^*$ that satisfy the verification equation.
 - (a) **Guessing Nonces:** Nonces n_1, n_2 are chosen uniformly at random from a large space (e.g., $q \approx 2^{128}$ or 2^{256}). The probability that $\mathcal{A}$ guesses the correct nonces is:

$$P_{\text{guess}} = \frac{q_{\text{nonce}}}{q},$$

where q_{nonce} is the number of guesses $\mathcal{A}$ makes.

(b) **Forging Values Consistent with DLA:** Even if $\mathcal{A}$ guesses the correct nonces, it must still produce $\Psi_{U_i}^*, \text{EK}_i^*, \sigma_{U_i}^*$ that satisfy the verification equation. Doing so without legitimate secrets (e.g., SK_{GSP}) reduces to solving the Discrete Logarithm Problem. By assumption, DLA is hard, so the probability that $\mathcal{A}$ succeeds here is $\epsilon_{\text{DLA}}(\lambda)$, which is negligible.

Combining the Probabilities: Using the union bound, the adversary's overall success probability is:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{RA}}}(\lambda) \leq P_{\text{reuse}} + P_{\text{guess}} + \epsilon_{\text{DLA}}(\lambda).$$

Substituting $P_{\text{reuse}} = 0$ and $P_{\text{guess}} = \frac{q_{\text{nonce}}}{q}$, we have:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{RA}}}(\lambda) \leq \frac{q_{\text{nonce}}}{q} + \epsilon_{\text{DLA}}(\lambda).$$

For q corresponding to a 128-bit or larger group, $\frac{q_{\text{nonce}}}{q}$ is negligible, and $\epsilon_{\text{DLA}}(\lambda)$ is also negligible. Thus, $\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{RA}}}(\lambda)$ is negligible.

Conclusion: Replaying old messages fails due to blockchain-verified nonce freshness. Forging fresh values requires solving DLA or successfully guessing large-entropy nonces, both of which are infeasible. Hence, the B²-GAS protocol is secure against replay attacks. $\square$

Game 4 (Security Against Brute-force Attacks): We define a security game $\mathcal{G}_{\text{BF}}$ between $\mathcal{A}$ and $\mathcal{C}$ to demonstrate the resistance of the protocol to brute-force attacks.

- 1) **Setup:** As before.
- 2) **Adversary's Goal:** $\mathcal{A}$ tries large numbers of guesses for PW_{U_i} and/or Bio_{U_i} to reproduce k_i .
- 3) **Winning Condition:** $\mathcal{A}$ wins if it finds a $(\text{PW}_{U_i}^*, \text{Bio}_{U_i}^*)$ that passes all checks.

Advantage: The advantage of the adversary in the above game is defined as $\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{BF}}}(\lambda) = \Pr[\mathcal{A} \text{ wins in } \mathcal{G}_{\text{BF}}]$.

Theorem 4 (Security Against Brute-force Attacks): Under the DLA, fuzzy extractor security, and the ROM assumptions, for any PPT adversary $\mathcal{A}$,

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{BF}}}(\lambda) \text{ is negligible.}$$

Assume for contradiction that there exists a PPT adversary $\mathcal{A}$ with non-negligible advantage $\epsilon(\lambda)$ in $\mathcal{G}_{\text{BF}}$.

Setup: The challenger $\mathcal{C}$ generates the system parameters, including:

- An elliptic curve group G of order $q \approx 2^\lambda$ with generator P .
- The GSP's key pair $(\text{SK}_{\text{GSP}}, \text{PK}_{\text{GSP}} = \text{SK}_{\text{GSP}} \cdot P)$.
- Hash functions $H_0, H_1, \dots$ modeled as random oracles.
- A fuzzy extractor to derive $(k_i, \tau_i) = \text{Gen}(\text{Bio}_{U_i})$ from user biometrics Bio_{U_i} .

The user U_i registers with a password PW_{U_i} , chosen from a space of entropy H_{pw} , and biometric data Bio_{U_i} , with effective entropy H_k for the derived key k_i . The system stores $\text{RPW}_{U_i} = H_0(\text{PW}_{U_i} \| n_0 \| k_i)$, where n_0 is a nonce ensuring uniqueness.

Adversary's Goal: The adversary $\mathcal{A}$ attempts to guess PW_{U_i} and/or Bio_{U_i} (equivalently, k_i) to produce a tuple $(\text{PW}_{U_i}^*, \text{Bio}_{U_i}^*)$ that satisfies the verification checks of the protocol. Essentially, $\mathcal{A}$ wants:

$$H_0(\text{PW}_{U_i}^* \| n_0 \| k_i^*) = \text{RPW}_{U_i},$$

where k_i^* is derived from the guessed biometrics $\text{Bio}_{U_i}^*$.

Adversary's Strategies and Reductions: We consider three possible strategies for $\mathcal{A}$ to succeed and show that each leads to a contradiction:

- 1) **Guessing the Password PW_{U_i} :** The password is chosen from a space of size approximately $2^{H_{\text{pw}}}$. Without further clues, $\mathcal{A}$ must guess PW_{U_i} uniformly at random. The probability of success in guessing PW_{U_i} correctly is:

$$P_{\text{guess}_{\text{pw}}} = 2^{-H_{\text{pw}}}.$$

- 2) **Guessing the Biometric-derived Key k_i :** Since k_i is derived from Bio_{U_i} via a fuzzy extractor:

$$(k_i, \tau_i) \leftarrow \text{Gen}(\text{Bio}_{U_i}),$$

the helper data τ_i does not reveal information that allows $\mathcal{A}$ to recover k_i without the correct biometric input. The effective entropy of k_i is H_k . Thus, guessing k_i (or equivalently Bio_{U_i}) has success probability:

$$P_{\text{guess}_{\text{bio}}} = 2^{-H_k}.$$

- 3) **Breaking the Hash Function H_0 :** If $\mathcal{A}$ cannot guess both PW_{U_i} and k_i , it might attempt to break the pre-image resistance of H_0 . Since H_0 is modeled as a random oracle and has an n -bit output (e.g., $n = 256$), the probability of inverting H_0 without querying it on the correct pre-image is:

$$P_{\text{break}_{\text{hash}}} = \frac{q_H}{2^n},$$

where q_H is the number of queries $\mathcal{A}$ makes to the random oracle.

Combining the Probabilities: For $\mathcal{A}$ to succeed, it must succeed in at least one of the events: guessing the password, guessing the biometric-derived key, or breaking H_0 . By the union bound:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{BF}}}(\lambda) \leq P_{\text{guess}_{\text{pw}}} + P_{\text{guess}_{\text{bio}}} + P_{\text{break}_{\text{hash}}}.$$

Substitute the probabilities:

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{BF}}}(\lambda) \leq 2^{-H_{\text{pw}}} + 2^{-H_k} + \frac{q_H}{2^n}.$$

Since each strategy fails with at most negligible probability, the overall advantage $\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{BF}}}(\lambda)$ of $\mathcal{A}$ in $\mathcal{G}_{\text{BF}}$ must also be negligible.

Conclusion: We reach a contradiction to the assumption that $\mathcal{A}$ has non-negligible advantage. Thus,

$$\text{Adv}_{\mathcal{A}, \mathcal{G}_{\text{BF}}}(\lambda) \text{ is negligible.}$$

This completes the proof of security against brute-force attacks. $\square$

VII. PERFORMANCE EVALUATION OF B²-GAS

This section provides a comprehensive evaluation of the B²-GAS system, encompassing both theoretical analysis and empirical validation of its performance.

TABLE 6. Computational complexity analysis of B²-GAS protocol phases.

Protocol Phase	Entity	Operations Performed	Complexity
Setup	GSP	ECC key generation ($SK \cdot P$), Hash function initialization	$O(n)$
	SC	Identity enrollment	$O(1)$
	User	Biometric feature extraction, Fuzzy extractor $Gen(\cdot)$, Hash computations	$O(m)$
Registration	GSP	ECC scalar multiplication, Hash computations, Encryption operations	$O(n)$
	SO	ECC scalar multiplication, Hash computations	$O(n)$
	SC	Store registration transactions	$O(1)$
	User	Biometric verification $Rep(\cdot)$, ECC multiplications, Hash computations	$O(m + n)$
Authentication	SO	ECC scalar multiplications, Hash computations	$O(n)$
	SC	ECC scalar multiplication verification, Hash computations	$O(n)$

n denotes the ECC security parameter (key size), and m denotes the biometric feature vector length.

A. COMPUTATIONAL COMPLEXITY ANALYSIS

This section quantitatively analyzes the computational complexity associated with the B²-GAS protocol. Table 6 summarizes the complexity of key operations across different protocol phases, categorized by the entity performing each operation. The analysis covers biometric operations (feature extraction, template enrollment, and reconstruction using fuzzy extractors), ECC operations (key generation, signature verification, and key agreement), cryptographic hashing operations (SHA-256), and blockchain interactions (data storage, transaction processing, queries, and smart contract execution).

The complexity analysis demonstrates that the B²-GAS protocol is computationally efficient, with most operations exhibiting constant complexity ($O(1)$) or linear complexity ($O(n)$ or $O(m)$) depending on cryptographic and biometric computations. The dominant factor influencing overall complexity is biometric operations, which scale linearly ($O(m)$) with respect to the biometric feature vector length. ECC operations also contribute to the overall complexity, scaling linearly ($O(n)$) relative to the ECC security parameter (key size). Given that both m and n are fixed and small in practical implementations, the overall computational cost remains lightweight. As a result, B²-GAS is well-suited for deployment in resource-constrained environments such as SIM cards and IoT devices.

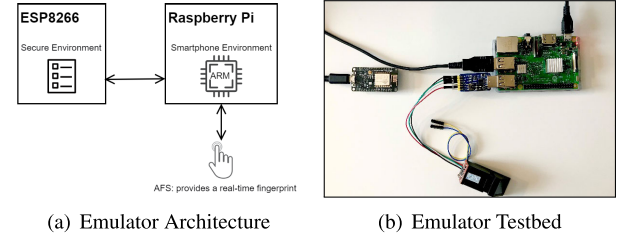
B. EMPIRICAL EVALUATION

This section provides a detailed description of the empirical evaluation of the B²-GAS system. It covers the emulation environment setup, biometric data processing, storage requirements, blockchain simulation, network configuration, and performance analysis results.

1) EMULATION SETUP

The smartphone environment is emulated using below components to evaluate the functionalities of B²-GAS:

- 1) **Adafruit Fingerprint Sensor (AFS):** This provides real-time fingerprint data via a serial interface supporting baud rates from 9,600 to 57,600 [33].

**FIGURE 3.** Emulator architecture and testbed.**TABLE 7.** Fingerprint and biometric fuzzy extractor.

Module	Elapsed Time	Size
Fingerprint image	N/A	74 KB
Fingerprint template	9.328 ms	38.15 KB
Gen($\cdot$)	0.644 ms	τ_i : 38.15 KB
Rep($\cdot$)	0.028 ms	N/A

- 2) **ESP8266 Board (ESPB):** Mimics the secure environment and it contains 64KB of RAM, Tensilica 32-bit microprocessor, and 4MB of flash memory [34].
- 3) **Raspberry Pi Model 3 B (RP3B):** Simulates the smartphone environment and has 1GB of RAM, a Broadcom BCM2837 processor, and 64GB of flash memory [35].

The AFS and ESPB modules transmit data to RP3B under the assumption that communication channels are secure. These channels utilize serial communication at different baud rates: 115,200 baud between the ESPB and RP3B, and 57,600 baud between the AFS and RP3B. In real systems, these channels are internal secure channels between the sensors and enclaves. Figures 3(a) and 3(b) illustrate the communication connectivity and the physical testbed, respectively.

2) BIOMETRIC DATA PROCESSING

Due to the limitations of the Adafruit Fingerprint Sensor (AFS), which only provides fingerprint images and not templates, the Python OpenCV library is used for template extraction. The extracted template is approximately 38.15 KB, derived from a 74 KB fingerprint image taken from AFS. The Biometric Fuzzy Extractor Gen function generates a random string (k_i) and helper data (τ_i) in 0.644 milliseconds, whereas the Rep function verifies new biometric data in 0.028 milliseconds (Table 7).

3) STORAGE REQUIREMENTS AND COMPUTATIONS

The storage requirements for the User (U) and Service Organization (SO) are summarized in Table 8. The user must store β_{U_i} , $Auth_{U_i}$, n_0 , and τ_i , totaling approximately 38.25 KB. The SO needs to store σ_{S_j} , amounting to approximately 0.04 KB.

The registration transactions formed by GSP are as follows: the user registration transaction includes ID_{U_i} , Ψ_{U_i} , $Enc_{PK_{GSP}}(QST_{U_i})$, $Enc_{PK_{GSP}}(ANS_{U_i})$, and τ_i , totaling approximately 38.23 KB, while the Service Organization

TABLE 8. User and service organization parameters.

User Parameters	Size	SO Parameters	Size
β_{U_i}	517 bits	σ_{S_j}	263 bits
Auth_{U_i}	262 bits		
τ_i	38.15 KB		
Total:	38.25 KB		0.04 KB

TABLE 9. Blockchain transactions: Structure and size.

Protocol Phase	Entity	Transaction	Size
Registration	User	$\text{ID}_{U_i}, \Psi_{U_i}, \text{QST}_{U_i}, \text{ANS}_{U_i}, \tau_i$	$(36 + 517 + 22 + 3) \text{ bits} + 38.15 \text{ KB} \approx 38.23 \text{ KB}$
	SO	$\text{ID}_{S_j}, \text{PK}_{S_j}$	$36 + 519 \text{ bits} \approx 0.07 \text{ KB}$
Authentication	SC	$\text{ID}_{S_j}, \Psi_{U_i}, \text{result}, \text{timestamp}$	$36 + 517 + 16 + 64 \text{ bits} \approx 0.08 \text{ KB}$

registration transaction includes ID_{S_j} and PK_{S_j} , totaling approximately 0.07 KB (Table 9). The computational complexities are assessed using empirical measurements implemented with Python's time library as follows: Registration computations for the user require approximately 20.10 milliseconds, whereas those for Service Organization necessitate only 0.03 milliseconds. This disparity is largely attributable to the computational overhead associated with biometric processing during the user registration. Similarly, user authentication takes approximately 20.91 milliseconds for User, in contrast to about 0.04 milliseconds for Service Organization. The addition of authentication processes contributes only 0.09 milliseconds to the Smart Contract computations when verifying a user for a Service Organization. These findings demonstrate a minimal computational burden on Service Organizations and the blockchain network while effectively leveraging the computational resources of the user's smartphone.

4) BLOCKCHAIN SIMULATION

The blockchain simulation was conducted on a local test network of Hyperledger Fabric [22], [36], using a Docker Desktop v.2.5.0.1 on a Windows 11 machine with an Intel Core i7-10750H (2.60GHz) CPU and 16 GB of RAM. The primary aim of this simulation was to demonstrate the correct functionality of messaging and interaction protocols in their basic configurations.

5) TEST NETWORK CONFIGURATION

The test network comprises two organizations, referred to as org1 and org2. Each organization includes one peer, namely 'peer0.org1' and 'peer0.org2'. Additionally, there is an 'orderer' responsible for managing and packaging transactions into blocks, as well as Certificate Authorities (CAs) for org1, org2, and the orderer to manage users and identities within the network. The GSP blockchain identity 'X.509 certificate' is obtained during the Setup Phase, whereas Service Organizations are registered during the Registration Phase.

The B²-GAS system utilizes a single Smart Contract (referred to as chaincode in Hyperledger Fabric) to reduce complexity and facilitate deployment. The contract includes the following functions:

- 1) *InitLedger()*: Initializes ledger with User, Service Organization, and Authentication data.
- 2) *RegisterUser()*: Executes the user registration transaction, accessible only by GSP.
- 3) *RegisterServiceOrganization()*: Executes the service organization registration transaction, accessible only by GSP.
- 4) *AuthAudit()*: Calculates the authentication equation, records results, and logs activity, accessible by Service Organizations.
- 5) *GetAuthAudit()*: Retrieves authentication results from the blockchain, accessible by both Service Organizations and GSP.

6) NETWORK CONFIGURATION SPECIFICATIONS

The blockchain Network is configured according to the Hyperledger Fabric basic network [37] with the following specifications: (1) 'Batch Timeout' of 2 seconds defining the duration after which transactions will be batched into a block; and (2) 'Batch Size' which determines the size of transactions for each block and it consists of three fields: 'Max Message Count = 10' for the maximum number of messages in each block, 'Absolute Max Bytes = 99MB' for the maximum bytes allowed for message serialization of each block, and 'Preferred Max Bytes = 512KB' indicating the preferred size for serialized messages in each batch. The Hyperledger Caliper evaluation tool [38] was used for the performance analysis.

7) PERFORMANCE ANALYSIS

The performance analysis demonstrates the system's transaction handling capabilities across six rounds of increasing transaction loads. Figure 4(a) shows a 100% success rate for transactions sent and processed, indicating robust performance and scalability for up to 1,000 transactions. However, the transaction rate is significantly influenced by the network configurations discussed in Section VII-B6. Figure 4(b) displays the latency, with both maximum and average latency rising with increased transaction load, peaking at 16.96 seconds and 12.77 seconds in the final round. The minimum latency remains low, signifying the system's ability to process transactions quickly even under higher loads. Figure 4(c) compares the send rate and throughput in transactions per second (TPS). The send rate consistently increases with the transaction load, reaching 224.5 TPS in the final round. Throughput displays variability, peaking at 52.3 TPS in the last round, suggesting potential bottlenecks in processing capability under higher loads. Overall, the system exhibits strong performance and scalability, with areas for optimization to improve processing consistency and response times.

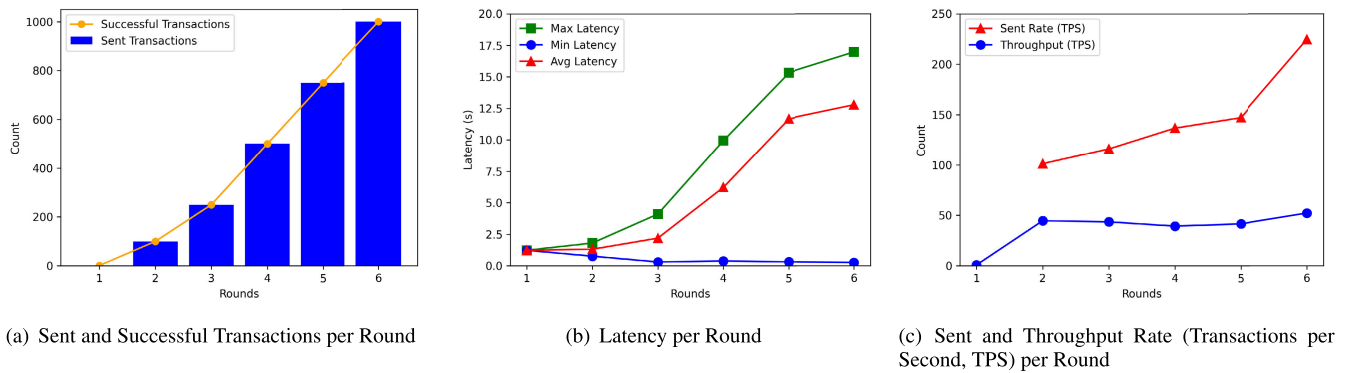


FIGURE 4. Performance evaluation results for B²-GAS.

VIII. CONCLUSION

In this study, we introduce B²-GAS, a biometric and blockchain-based global authentication system designed for secure and transparent e-government services in smart cities. B²-GAS leverages smartphone biometrics for strong identification while protecting user privacy through secure enclaves within the SIM card environment. The system eliminates single points of failure through blockchain technology, ensuring tamper-proof transaction storage and efficient processing of high-volume authentication requests. Operating through Setup, Registration, and Authentication phases with Smart Contract facilitation, B²-GAS extends beyond e-government to applications in smart city services, national identity management, and telemedicine, where secure authentication is critical. Future work includes comprehensive quantitative evaluation and implementation within a real-world SIM card environment or Trusted Execution Environment (TEE) such as OP-TEE [39], [40]. We plan to develop a Trusted Application for the OP-TEE environment to achieve more accurate results, which must be initially deployed by manufacturers or utilized within a TEE virtualization architecture such as TEEv [41]. B²-GAS represents a novel approach to global authentication by combining biometrics, SIM card technology, and blockchain to provide a robust, transparent, and privacy-preserving solution ideal for various applications requiring strong security and user privacy.

REFERENCES

- [1] M. do Rosário Matos Bernardo, "Smart city governance: From e-government to smart governance," in *Smart Cities and Smart Spaces: Concepts, Methodologies, Tools, and Applications*. Hershey, PA, USA: IGI Global, 2019, pp. 196–232.
- [2] S. Malodia, A. Dhir, M. Mishra, and Z. A. Bhatti, "Future of e-government: An integrated conceptual framework," *Technol. Forecasting Social Change*, vol. 173, Dec. 2021, Art. no. 121102.
- [3] P. M. Rao and B. D. Deebak, "Security and privacy issues in smart cities/industries: Technologies, applications, and challenges," *J. Ambient Intell. Humanized Comput.*, vol. 14, no. 8, pp. 10517–10553, Aug. 2023.
- [4] C. Mazzocca, A. Acar, S. Ulugac, R. Montanari, P. Bellavista, and M. Conti, "A survey on decentralized identifiers and verifiable credentials," 2024, *arXiv:2402.02455*.
- [5] R. Zhang, R. Xue, and L. Liu, "Security and privacy for healthcare blockchains," *IEEE Trans. Services Comput.*, vol. 15, no. 6, pp. 3668–3686, Nov. 2022.
- [6] A. Ifikhar, K. N. Qureshi, M. Shiraz, and S. Albahli, "Security, trust and privacy risks, responses, and solutions for high-speed smart cities networks: A systematic literature review," *J. King Saud Univ.-Comput. Inf. Sci.*, vol. 35, no. 9, Oct. 2023, Art. no. 101788.
- [7] L. Yang, N. Elisa, and N. Eliot, "Privacy and security aspects of e-government in smart cities," in *Smart Cities Cybersecurity and Privacy*. Amsterdam, The Netherlands: Elsevier, 2019, pp. 89–102.
- [8] M. AlRousan and B. Intrigila, "Multi-factor authentication for e-Government services using a smartphone application and biometric identity verification," *J. Comput. Sci.*, vol. 16, no. 2, pp. 217–224, Feb. 2020.
- [9] V. Geteloma, C. K. Ayo, and R. N. Goddy-Wurlu, "A proposed unified digital id framework for access to electronic government services," *J. Phys., Conf. Ser.*, vol. 1378, no. 4, Dec. 2019, Art. no. 042039.
- [10] K. Maazouz, H. Benlahmer, and N. Achtaich, "Identification system using mobile device enabled NFC," *Int. J. Comput. Appl.*, vol. 107, no. 7, pp. 37–39, Dec. 2014.
- [11] X. Xiang, M. Wang, and W. Fan, "A permissioned blockchain-based identity management and user authentication scheme for e-health systems," *IEEE Access*, vol. 8, pp. 171771–171783, 2020.
- [12] Md. R. Ahmed, A. K. M. M. Islam, S. Shatabda, and S. Islam, "Blockchain-based identity management system and self-sovereign identity ecosystem: A comprehensive survey," *IEEE Access*, vol. 10, pp. 113436–113481, 2022.
- [13] R. Páez, M. Pérez, G. Ramírez, J. Montes, and L. Bouvarel, "An architecture for biometric electronic identification document system based on blockchain," *Future Internet*, vol. 12, no. 1, p. 10, Jan. 2020.
- [14] N. Elisa, L. Yang, F. Chao, and Y. Cao, "A framework of blockchain-based secure and privacy-preserving e-government system," *Wireless Netw.*, vol. 29, no. 3, pp. 1005–1015, Apr. 2023.
- [15] N. Elisa, L. Yang, F. Chao, N. Naik, and T. Boongoen, "A secure and privacy-preserving e-government framework using blockchain and artificial immunity," *IEEE Access*, vol. 11, pp. 8773–8789, 2023.
- [16] H. H. Al-Ameri and S. Ayyaz, "A blockchain-based secure mutual authentication system for e-government services," in *Proc. 3rd Int. Sci. Conf. Eng. Sci. (ISCES)*, May 2023, pp. 19–24.
- [17] P. M. Rao and B. D. Deebak, "A comprehensive survey on authentication and secure key management in Internet of Things: Challenges, countermeasures, and future directions," *Ad Hoc Netw.*, vol. 146, Jul. 2023, Art. no. 103159.
- [18] Oracle Corp. (2024). *Java Card 3 Platform Development Kit User Guide, Classic Edition*. [Online]. Available: <https://docs.oracle.com/javacard/3.0.5/guide/index.html>
- [19] K. Markantonakis and R. N. Akram, "Multi-application smart card platforms and operating systems," in *Smart Cards, Tokens, Security and Applications*. Cham, Switzerland: Springer, 2017, pp. 59–92.
- [20] N. Tiwari, P. Ranjan, P. K. Biswal, C. Barde, and N. Sinha, "Survey and analysis of blockchain technologies with respect to: Properties, algorithms, architecture, models, evolution and framework," *Multimedia Tools Appl.*, vol. 2024, pp. 1–45, Jun. 2024.

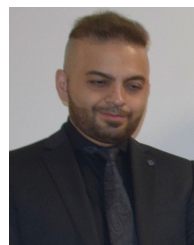
- [21] H. M. Kim, H. Turesson, M. Laskowski, and A. F. Bahreini, "Permissionless and permissioned, technology-focused and Business needs-driven: Understanding the hybrid opportunity in blockchain through a case study of insolar," *IEEE Trans. Eng. Manag.*, vol. 69, no. 3, pp. 776–791, Jun. 2022.
- [22] E. Androulaki et al., "Hyperledger fabric: A distributed operating system for permissioned blockchains," in *Proc. 13th EuroSys Conf.*, Apr. 2018, pp. 1–15.
- [23] S. Wang, L. Ouyang, Y. Yuan, X. Ni, X. Han, and F.-Y. Wang, "Blockchain-enabled smart contracts: Architecture, applications, and future trends," *IEEE Trans. Syst., Man, Cybern., Syst.*, vol. 49, no. 11, pp. 2266–2277, Nov. 2019.
- [24] S. A. Abdulrahman and B. Alhayani, "A comprehensive survey on the biometric systems based on physiological and behavioural characteristics," *Mater. Today, Proc.*, vol. 80, pp. 2642–2646, Jan. 2023.
- [25] P. K. Singh, N. Kumar, and B. K. Gupta, "Smart cards with biometric influences: An enhanced ID authentication," in *Proc. Int. Conf. Cutting-Edge Technol. Eng. (Icon-CuTE)*, Nov. 2019, pp. 33–39.
- [26] S. Furnell, "Biometric technology and user identity," in *Regulating Cyber Technologies: Privacy Vs Security*. Singapore: World Scientific, 2023, pp. 81–110.
- [27] S. S. Sahoo, S. Mohanty, and B. Majhi, "A secure three factor based authentication scheme for health care systems using IoT enabled devices," *J. Ambient Intell. Humanized Comput.*, vol. 12, no. 1, pp. 1419–1434, Jan. 2021.
- [28] S. Ullah, J. Zheng, N. Din, M. T. Hussain, F. Ullah, and M. Yousaf, "Elliptic curve cryptography; applications, challenges, recent advances, and future trends: A comprehensive survey," *Comput. Sci. Rev.*, vol. 47, Feb. 2023, Art. no. 100530.
- [29] B. Ying and A. Nayak, "Lightweight remote user authentication protocol for multi-server 5G networks using self-certified public key cryptography," *J. Netw. Comput. Appl.*, vol. 131, pp. 66–74, Apr. 2019.
- [30] A. Vangala, A. K. Sutrala, A. K. Das, and M. Jo, "Smart contract-based blockchain-envisioned authentication scheme for smart farming," *IEEE Internet Things J.*, vol. 8, no. 13, pp. 10792–10806, Jul. 2021.
- [31] I. Ul Haq, J. Wang, and Y. Zhu, "Secure two-factor lightweight authentication protocol using self-certified public key cryptography for multi-server 5G networks," *J. Netw. Comput. Appl.*, vol. 161, Jul. 2020, Art. no. 102660.
- [32] S. Dey and A. Hossain, "Session-key establishment and authentication in a smart home network using public key cryptography," *IEEE Sensors Lett.*, vol. 3, no. 4, pp. 1–4, Apr. 2019.
- [33] Adafruit Industries. (2024). *Monochrome 0.96 128×64 OLED Graphic Display*. Accessed: Mar. 9, 2024. [Online]. Available: <https://www.adafruit.com/product/751>
- [34] Components101. (2024). *NodeMCU ESP8266 Pinout, Features, Datasheet*. Accessed: Mar. 9, 2024. [Online]. Available: <https://components101.com/development-boards/nodemcu-esp8266-pinout-features-and-datasheet>
- [35] Raspberry Pi Found. (2024). *Raspberry Pi 3 Model B*. Accessed: Mar. 9, 2024. [Online]. Available: <https://www.raspberrypi.com/products/raspberry-pi-3-model-b/>
- [36] Q. Nasir, I. A. Qasse, M. Abu Talib, and A. B. Nassif, "Performance analysis of hyperledger fabric platforms," *Secur. Commun. Netw.*, vol. 2018, Sep. 2018, Art. no. 3976093.
- [37] Hyperledger Fabric. (2024). *Using the Fabric Test Network—Hyperledger Fabric Docs Main Documentation*. [Online]. Available: https://hyperledger-fabric.readthedocs.io/en/latest/test_network.html
- [38] Hyperledger. (2024). *Hyperledger Caliper V0.6.0 Getting Started Guide*, 2024. Accessed: Jul. 22, 2024. [Online]. Available: <https://hyperledger-caliper.github.io/caliper/v0.6.0/>
- [39] A. Nehal and P. Ahlawat, "Securing IoT applications with OP-TEE from hardware level OS," in *Proc. 3rd Int. Conf. Electron., Commun. Aerosp. Technol. (ICECA)*, Jun. 2019, pp. 1441–1444.
- [40] Linaro. (2024). *OP-TEE: Open Portable Trusted Execution Environment*. Accessed: Jul. 5, 2024. [Online]. Available: <https://optee.readthedocs.io/en/latest/general/about.html>
- [41] W. Li, Y. Xia, L. Lu, H. Chen, and B. Zang, "TEEv: Virtualizing trusted execution environments on mobile platforms," in *Proc. 15th ACM SIGPLAN/SIGOPS Int. Conf. Virtual Execution Environ.*, Apr. 2019, pp. 2–16.



NAVID KHALILI received the Master of Applied Science degree in electrical and computer engineering from the University of Ottawa. He was an Active Member of the Broadband Wireless and Internetworking Research Laboratory, University of Ottawa. During this period, he conducted research on blockchain technology, the IoT, and telecommunications. Prior to his academic endeavors, he gained valuable experience working with the Research and Development Department, Samsung Electronics, Tehran. Expanding his expertise, he is currently with the Research and Development Department of a U.S.-based company specializing in early childhood intervention programs. His extensive experience in the software industry has been pivotal in driving innovation and advancing various research and development projects.



DIMITRIOS MAKRAKIS is currently with the School of Electrical Engineering and Computer Science (EECS), University of Ottawa, and the Founding Director of the Broadband and Wireless Research Laboratory and the Bio-Communication and Nano-Networks Research Laboratory. During his tenure as a Faculty Member with Western University, he founded and directed the Advanced Communications Engineering Center (ACEC); and an Advanced Telecommunications Research Facility, established with the joint support of Western University, Bell Canada, and Bay Networks. He has published more than 300 research articles in reputable journals and conferences, holds patents, co-authored book chapters, and has contributed to ITU's standardization initiatives. His current research revolves around the subjects of nano-communications and nano-networks, blockchain (theory and applications), cyber-security, and wireless networks.



YASER BASERI received the Ph.D. degree in computer science from the University of Montreal, in 2018. He is currently a Research Associate with the University of Montreal, where he previously led the Cybersecurity Research and Development Team, Canadian Institute for Cybersecurity (CIC), Fredericton, NB, Canada. He has continued his research journey as a Research Fellow with CIRRELT and a Research Assistant with the Sharif University of Technology, Institute of Electronics Research. His collaborations with industry giants, such as Scotiabank, RBC, Bell, and Siemens have been instrumental in propelling cybersecurity forward. His expertise encompasses post-quantum cryptography, privacy-preserving technologies, and cyber threat analytics, showcasing his dedication to advancing security in the digital era.



ABDELHAKIM SENHAJI HAFID is currently a Full Professor with the University of Montreal. He is the founding director of Network Research Laboratory and Montreal Blockchain Laboratory. He is a Research Fellow with CIR-RELT, Montreal, Canada. He published more than 260 journal and conference papers. He also holds three U.S. patents. Prior to joining the University of Montreal, he spent several years, as a Senior Research Scientist with Bell Communications Research (Bellcore), Morristown, NJ, USA, working in the context of major research projects on the management of next-generation networks. He has extensive academic and industrial research experience in the area of communication networks and distributed systems. His current research interests include blockchain, fog/edge computing, cybersecurity, and intelligent transport systems.

• • •